



Agliberto - Locação de video games - correção

Sites: <https://archive.mozilla.org> <http://localhost:8080>

Generated on qui., 18 jun. 2026 17:26:14

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Nível de Risco	Number of Alerts
Alto	0
Médio	1
Baixo	1
Informativo	1

Alertas

Nome	Nível de Risco	Number of Instances
Método Fraco de Autenticação	Médio	4
X-Content-Type-Options Header Missing	Baixo	2
Retrieved from Cache	Informativo	2

Alert Detail

Médio	Método Fraco de Autenticação
Descrição	O método básico de autenticação ou digest tem sido utilizado em uma conexão insegura. As credenciais podem ser lidas e reutilizadas por alguém com acesso a rede.
URL	http://localhost:8080/
Node Name	http://localhost:8080/
Método	GET
Ataque	
Evidence	www-authenticate: Basic realm="Realm"
Other Info	
URL	http://localhost:8080/h2-console
Node Name	http://localhost:8080/h2-console

Método	GET
Ataque	
Evidence	www-authenticate: Basic realm="Realm"
Other Info	
URL	http://localhost:8080/jogos
Node Name	http://localhost:8080/jogos
Método	GET
Ataque	
Evidence	www-authenticate: Basic realm="Realm"
Other Info	
URL	http://localhost:8080/usuarios
Node Name	http://localhost:8080/usuarios
Método	GET
Ataque	
Evidence	www-authenticate: Basic realm="Realm"
Other Info	
Instances	4
Solution	Protect the connection using HTTPS or use a stronger authentication mechanism.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
CWE Id	326
WASC Id	4
Plugin Id	10105

Baixo	X-Content-Type-Options Header Missing
Descrição	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://archive.mozilla.org/pub/system-addons/newtab/newtab-154.1.0-build1/newtab.xpi
Node Name	https://archive.mozilla.org/pub/system-addons/newtab/newtab-154.1.0-build1/newtab.xpi
Método	GET
Ataque	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://archive.mozilla.org/pub/system-addons/newtab/newtab-154.2.0-build1/newtab.xpi
Node	

Name	https://archive.mozilla.org/pub/system-addons/newtab/newtab-154.2.0-build1/newtab.xpi
Método	GET
Ataque	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	2
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informativo	Retrieved from Cache
Descrição	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://archive.mozilla.org/pub/system-addons/newtab/newtab-154.1.0-build1/newtab.xpi
Node Name	https://archive.mozilla.org/pub/system-addons/newtab/newtab-154.1.0-build1/newtab.xpi
Método	GET
Ataque	
Evidence	HIT
Other Info	
URL	https://archive.mozilla.org/pub/system-addons/newtab/newtab-154.2.0-build1/newtab.xpi
Node Name	https://archive.mozilla.org/pub/system-addons/newtab/newtab-154.2.0-build1/newtab.xpi
Método	GET
Ataque	
Evidence	HIT
Other Info	
Instances	2
	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:

Solution	Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050